

KIIRA MOTORS CORPORATION

HEALTH AND WELLNESS MANAGEMENT SYSTEM

ARCHITECTURE DOCUMENT

Field	Detail
Document name	Architecture Document
Reference number	KMC.DQHSE.08/26-SP002
Document description	Technical architecture of the Health and Wellness Management System covering service topology, data ownership, identity, deployment and the decisions behind them
Prepared by	Akanga Andrew, Software Engineering Intern, Department of Quality, Health, Safety and Environment
Issue date	11/08/2026
Version	002
Classification	Internal, Restricted to KMC ICT and the Department of Quality, Health, Safety and Environment

Table of Contents

1 Introduction.....	4
1.1 Purpose.....	4
1.2 Guiding Constraints.....	4
1.3 Technology.....	4
2 Service Topology.....	4
2.1 Overview.....	4
2.2 Why Not a Single Application.....	5
2.3 Communication.....	6
3 Identity and Session.....	6
3.1 The Backend for Frontend Pattern.....	6
3.2 Roles.....	6
3.3 Account Administration.....	7
4 Data.....	7
4.1 Ownership Rules.....	7
4.2 The Clinical Schema.....	7
4.3 Snapshots on Forms.....	7
5 Deployment.....	8
5.1 Environments.....	8
5.2 Production Considerations.....	8
5.3 Observability.....	8
6 Maintainability.....	9
6.1 Known Limitations.....	9
7 Handover.....	9

List of Figures

Figure 2.1: Service Topology and Request Path.....	5
Figure 5.1: Separation Between User Testing and Production.....	8

List of Tables

Table 1.1: Technology Choices and Their Reasons.....	4
Table 2.1: Services and What Each Owns.....	5
Table 3.1: Roles as Held in the Identity Provider.....	6
Table 4.1: Data Ownership Rules.....	7
Table 5.1: Deployment Constraints for Production.....	8
Table 6.1: Measures That Keep the Topology Maintainable.....	9
Table 6.2: Known Limitations and Their Consequences.....	9
Table 7.1: Position at Handover.....	9
Table 7.2: Architecture Document Sign Off.....	10

1 Introduction

1.1 Purpose

This document describes how the Health and Wellness Management System is built. It is written for KMC ICT, who will host the system and later maintain it, and for whoever inherits the code. It records not only what the structure is but why it was chosen, so that a future maintainer can tell a deliberate decision from an accident.

1.2 Guiding Constraints

Four constraints shaped the architecture more than any preference did.

- Clinical data is special personal data under the Data Protection and Privacy Act, 2019, and the separation protecting it must be structural rather than procedural.
- Microservices are the architectural standard of the Corporation, following the precedent set by the Velo system.
- KMC ICT works in Go, so the backend is written in Go.
- The system was built by one intern whose attachment is ending, so operational complexity that a small team cannot carry is itself a defect.

1.3 Technology

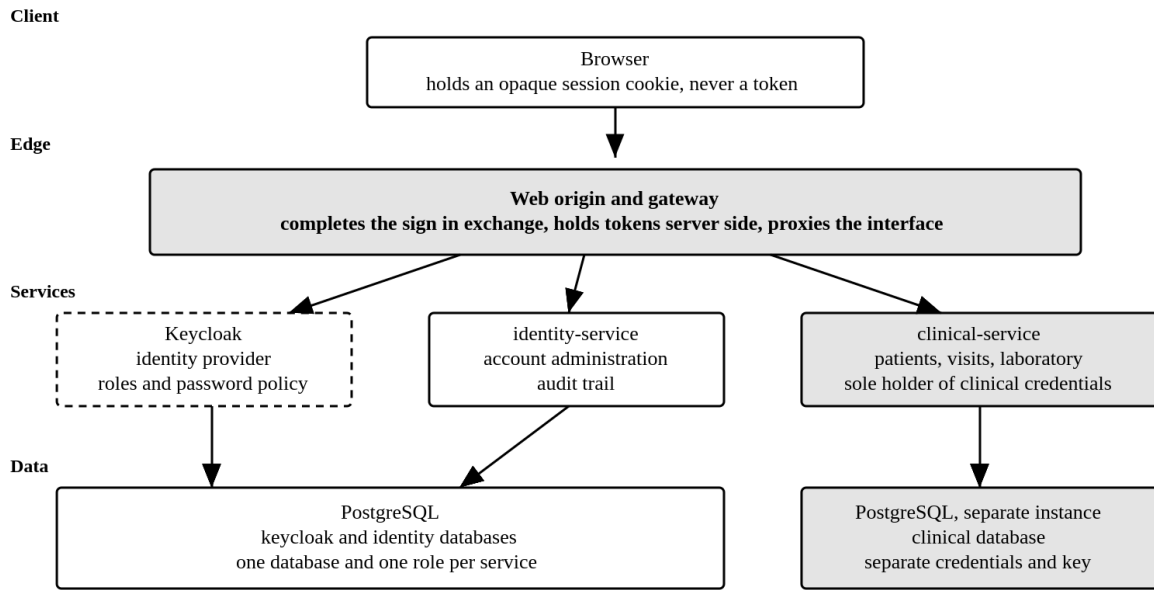
Table 1.1: Technology Choices and Their Reasons

S/N	Layer	Choice	Reason
1	Backend	Go with the chi router	Matches the standard KMC ICT works in. Single binary deployment suits on premise hosting
2	Persistence	PostgreSQL 16	Mature, well understood, and supports the separation the clinical context requires
3	Identity	Keycloak	Provides password policy, lockout, multi factor and later corporate single sign on without application code
4	Interface	React with TypeScript	Matches the reviewed prototype, so the approved design carries across unchanged
5	Observability	Prometheus and Grafana	Operational monitoring for ICT, separate from the divisional dashboard
6	Local environment	Docker Compose	One command brings the whole system up on a laptop
7	Deployment target	Kubernetes manifests for k3s	Written in parallel so production is a deployment change rather than a rewrite

2 Service Topology

2.1 Overview

The system is a set of independently deployable services, one per bounded context, behind a single gateway. Each owns its own database and exposes its data only through its own interface.



The clinical database is a separate instance. No other service holds a credential for it

Figure 2.1: Service Topology and Request Path

The clinical service shown in Figure 2.1 is the only workload issued a credential for the clinical database. That is not a deployment preference. It is the mechanism that makes the access rule structural, because a defect in another service cannot read a patient record when it holds nothing with which to try.

Table 2.1: Services and What Each Owns

S/N	Service	Owens	Special Conditions
1	Gateway	Sign in exchange, session, routing to services	Holds no data and no business rule
2	Identity	Account administration and the administrative audit trail	Acts on Keycloak through its own service account, never the user token
3	Clinical	Patients, visits, laboratory requisitions and referrals	Separate database instance, separate credentials, separate key
4	Web	The single public origin, serving the interface	Proxies the sign in and interface paths to the gateway

Two further services are specified and not yet built. Occupational, covering ergonomics and industrial hygiene, and metrics, covering monthly returns and indicator computation. They are named here because their boundaries are already decided and the interface already routes to them.

2.2 Why Not a Single Application

An earlier draft of this architecture chose a modular monolith. The reasoning was a small user population, no independently scaling workload and a single maintainer, and on those grounds it was correct.

That decision was superseded for two reasons. The Corporation stated microservices as its standard, and alignment with that standard is a precondition of ICT accepting the system. More importantly, the split strengthens the property that matters most here. Under a single application the rule that only the clinical context holds clinical credentials was enforced by code review, because every context ran in one process with one configuration. Under this arrangement it is enforced by deployment.

The cost is real and is stated plainly. There are more moving parts to run than a single application would require, and that cost lands on whoever maintains the system after handover. Section 6 sets out the specific measures that hold it down.

2.3 Communication

Services communicate over HTTP with JSON. The gateway attaches a bearer token to every proxied call, and each service validates that token independently rather than trusting the gateway to have done so.

One communication rule is not negotiable. No service other than the clinical service reads a clinical record. Where another context requires clinical information it receives counts and non identifying facts, never records. A reporting service therefore receives the number of visits in a period and never the visits themselves.

3 Identity and Session

3.1 The Backend for Frontend Pattern

The browser never holds a token. The gateway completes the sign in exchange with Keycloak, keeps the resulting tokens in server side session state, and returns to the browser an opaque session identifier in a cookie marked HttpOnly, Secure and SameSite.

This is the single most consequential decision in the identity design. In a system that holds health data, a token readable by any script on the page is not acceptable, and that risk is what the gateway exists to remove. A consequence worth stating is that the browser cannot call a service directly, so every authenticated call passes through one place where it can be inspected.

3.2 Roles

Roles are held in Keycloak and carried on the access token. The interface reads them to decide what to render, and every service checks them again to decide what to permit. The interface hiding a control is a courtesy. Refusing the request is the control.

Table 3.1: Roles as Held in the Identity Provider

S/N	Role	Purpose	Clinical Scope
1	hwms-officer	Health and Wellness Officer, the clinical role	Yes, and it is the only role that carries it
2	hwms-manager	Read only operations, plus account administration	No
3	hwms-director	Read only executive summaries	No

Roles are read from the access token rather than the identity token. Keycloak places realm roles on the access token and by default leaves them off the identity token entirely, so reading them from the identity token yields an empty set and signs a user in with no role and no navigation. That failure occurred once during build and is now covered by an automated test. Taking roles from the access token also keeps the gateway view of a caller identical to what the services enforce on, since that is the token forwarded to them.

3.3 Account Administration

The manager creates officer and director accounts through the identity service. The manager token is never used to administer the identity provider. The service authorises the manager and then acts through its own service account, so a stolen manager token cannot create accounts directly.

The manager cannot grant the manager role. Account administration expands only by a decision taken outside that screen, which limits what a single mistaken or compromised manager session can do. Every creation, enabling and disabling is written to the audit trail.

4 Data

4.1 Ownership Rules

Table 4.1: Data Ownership Rules

S/N	Rule	Statement
1	One database per service	A service reads and writes its own database and no other
2	Clinical separation	The clinical database is a separate instance with separate credentials and a separate encryption key
3	No cross context join	A reference across a context boundary is an identifier with no foreign key. Integrity across boundaries is an application concern
4	Soft deletion	A record that has been referenced is marked deleted rather than removed
5	Versioned change	Schema change is applied through numbered migration files held in source control and applied at startup
6	Append only logs	The audit trail and the clinical access log accept inserts and reads only, enforced by the database role

4.2 The Clinical Schema

The clinical context holds five tables. Patients, visits, the state and content of each section of a visit, laboratory requisitions with the investigations requested against them, and the clinical access log.

Section state is stored alongside section content rather than inferred from whether content exists. That is what allows the record to distinguish a section nobody has touched from one the officer decided does not apply, which is the distinction that makes a partially completed record auditable.

Vital signs are held as a document rather than as columns. The set is stable but sparsely populated, because a minor complaint records none of it, and twelve mostly empty columns model that worse than one document does.

4.3 Snapshots on Forms

A laboratory requisition and a referral each carry a snapshot of the patient information printed on them, taken when the form was raised. A later correction to the registry does not rewrite a form that has already gone to the laboratory or to a receiving facility. The printed sheet and the stored record continue to agree.

5 Deployment

5.1 Environments

Three environments are defined. A local environment brought up by one command on a developer machine, a user testing environment on KMC controlled infrastructure holding synthetic data only, and a production environment that has not been requested and is not covered by this document.

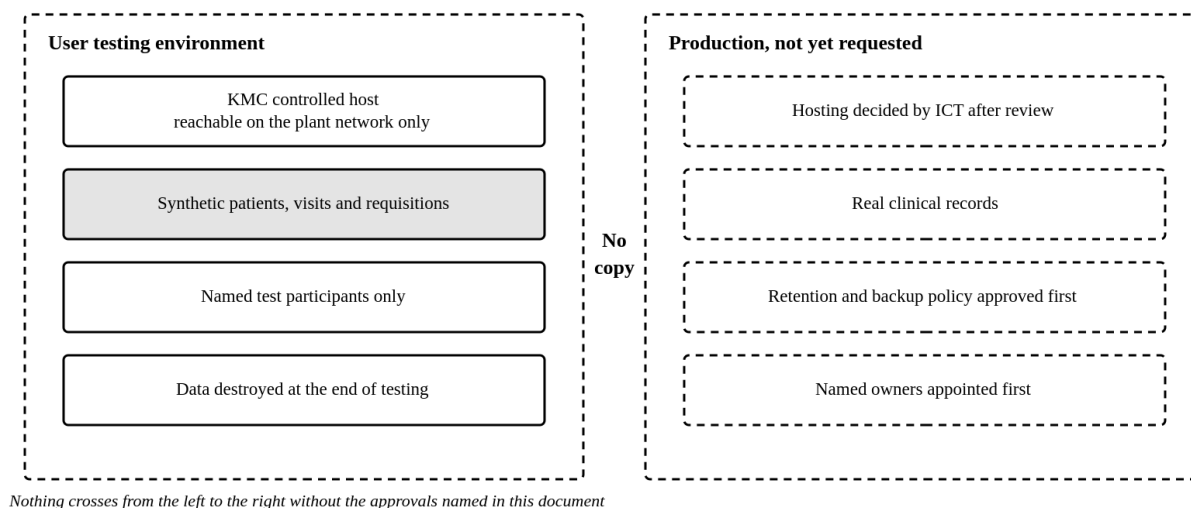


Figure 5.1: Separation Between User Testing and Production

The separation in Figure 5.1 is a requirement rather than a convention. No real clinical record is copied into a testing environment at any point.

5.2 Production Considerations

Table 5.1: Deployment Constraints for Production

S/N	Constraint	Detail
1	Gateway replicas	The gateway runs as a single replica until its session store is shared. Two replicas would not share sessions and users would appear to be signed out at random
2	Secrets	No credential is held in the repository. Values are supplied by ICT from a controlled source. Development defaults must never reach a cluster
3	Clinical database isolation	A network policy permits only the clinical service to open a connection to the clinical database, so that even a leaked credential is not reachable
4	Transport	Encryption terminates at the ingress. Session cookies are marked secure wherever transport encryption is present
5	Backups	Nightly encrypted backup with the clinical backup under a separate key, and a restore tested quarterly
6	Orchestration	Kubernetes manifests are provided for k3s. If ICT prefers another arrangement the manifests are discarded and nothing else changes

5.3 Observability

Each service exposes operational metrics which Prometheus collects and Grafana presents. Route templates are used as metric labels, so one address serves as one series rather than one per patient. That

is a privacy rule and a practical one at the same time, since identifiers as labels would also make the metrics database unusable.

No clinical content reaches any log line, metric label or trace. Grafana is for operating the system and is not a second route to divisional data. No dashboard there queries clinical data and none reproduces an indicator.

6 Maintainability

A service per context is only maintainable by a small team if the cost of an additional service is close to zero. Six measures keep it there and none of them is optional.

Table 6.1: Measures That Keep the Topology Maintainable

S/N	Measure	Detail
1	One repository	All services, the interface, the deployment manifests and the migrations sit together. A change spanning services is one commit and one review
2	One shared library	Configuration, logging, health, metrics, database access, migrations and token validation are written once and imported
3	One service skeleton	A new service is the skeleton plus its domain code. A service that reimplements the shared library has diverged
4	One pipeline	The same build and test path serves every service
5	One local command	The whole system starts on a laptop with a single command, so a new joiner is productive the same day
6	One test that blocks merges	The clinical access suite runs on every build and fails the build if any role other than the officer reaches a clinical route

6.1 Known Limitations

Table 6.2: Known Limitations and Their Consequences

S/N	Limitation	Consequence	Resolution
1	Session state is held in the gateway process	One replica only. A restart signs everybody out	Move the session store behind the existing interface to a shared store
2	Development secrets are in the repository	Acceptable on a laptop, unacceptable anywhere else	Supplied by ICT from a controlled source before any deployment
3	No continuous integration pipeline	Nothing enforces the build and tests on merge	Configure once a KMC source control remote exists
4	Logs and traces are not aggregated	Diagnosis requires reading each service in turn	Add log and trace collection alongside the existing metrics
5	Amendment of a signed visit is not implemented	A signed visit can be read but not corrected	Build the appended amendment before real records are entered

7 Handover

The system was built during a student attachment that is ending. The following is recorded so that the work can be continued by another party.

Table 7.1: Position at Handover

S/N	Item	Position
1	Built and working	Sign in, roles, account administration, patient registry, clinic visits with section state and signing, laboratory requisitions with results and a printable form, and the consolidated patient record
2	Specified and not built	Referrals, ergonomics, industrial hygiene, monthly returns and indicator computation
3	Highest priority next step	Settle the decisions listed in the requirements specification, in particular referral authorisation and record retention
4	Principal design risk	Erosion of the clinical access rule under management pressure. It is recorded with its reasoning so that any change is made deliberately and by an authorised party
5	Principal delivery risk	No named owner after the attachment ends. This is a release blocker rather than a preference
6	Where the truth lives	The supplied forms and the divisional dashboard are the primary sources. Everything else is derived from them or marked as a proposal

Table 7.2: Architecture Document Sign Off

Role	Name	Signature	Date
Prepared by, Software Engineering Intern			
Reviewed by, KMC ICT			
Approved by, Head of Department, Quality, Health, Safety and Environment			